Historia de Usuario
HU-RF-01: Gestión de Usuarios

Documentación técnica y evidencias de prueba

Sistema: FarmaExpres (Inventario Farmacéutico)
Versión del documento: 1.0
Fecha: 2026-03-03

1. Propósito

Esta historia de usuario describe cómo un Administrador (Admin) gestiona la creación de usuarios en el sistema, asegurando: (1) datos obligatorios, (2) no duplicidad de cuentas, (3) asignación de roles, (4) almacenamiento seguro de contraseñas y (5) registro de acciones en bitácora.

2. Requerimiento asociado

RF-01: Registro de usuarios con asignación de roles (Administrador / Empleado).

3. Precondiciones y preparación del entorno

Antes de ejecutar las pruebas de HU-RF-01, se deben cumplir los siguientes pasos para que el flujo funcione correctamente:

- Cargar los roles base en la tabla Rol (si está vacía).
- Verificar que existan al menos dos roles: ADMIN y EMPLEADO.
- Contar con un usuario administrador (Admin) registrado en la base de datos, ya que solo este rol puede crear nuevos usuarios.
- Tener disponible un token válido del Admin para consumir los endpoints protegidos (ej. desde Postman).

3.1 Cargar roles en la base de datos

Si la tabla Rol no tiene información, se insertan los roles mínimos necesarios. Esto garantiza que, al crear un usuario, el sistema pueda asociarlo a un rol existente.

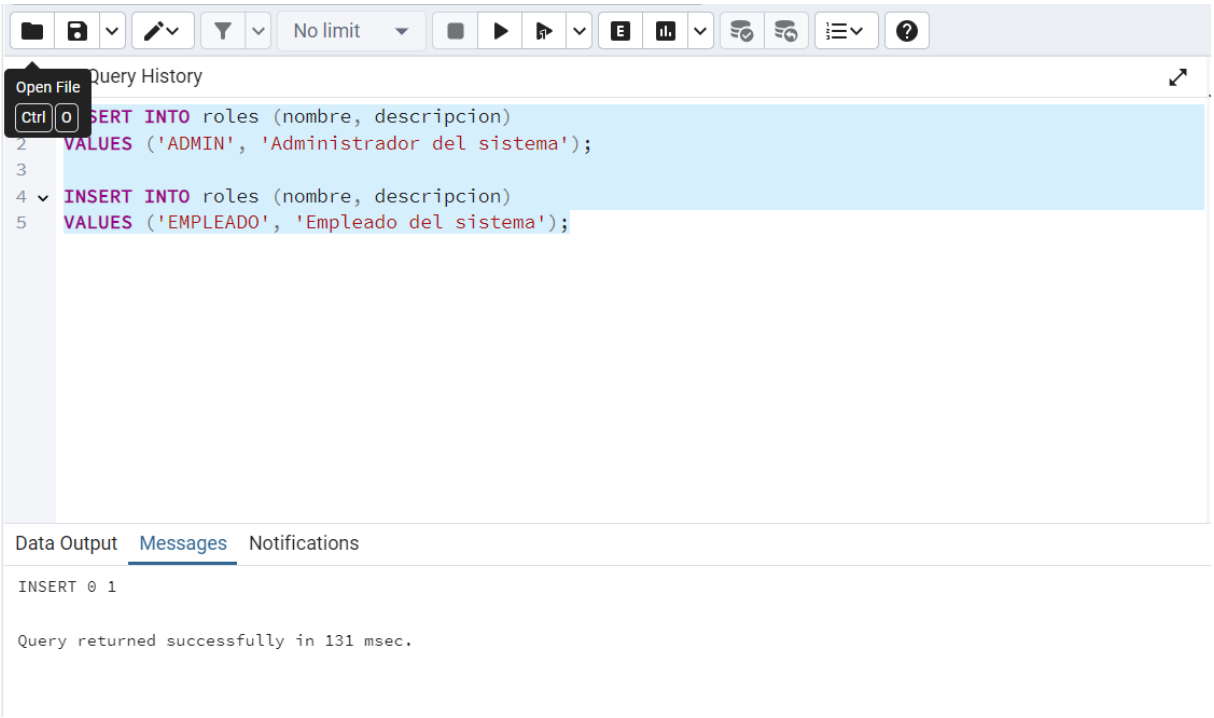

Figura 1. Inserción de roles en la tabla Rol (evidencia).

3.2 Verificar roles registrados

Luego se realiza una consulta para confirmar que los roles quedaron almacenados correctamente en la base de datos.

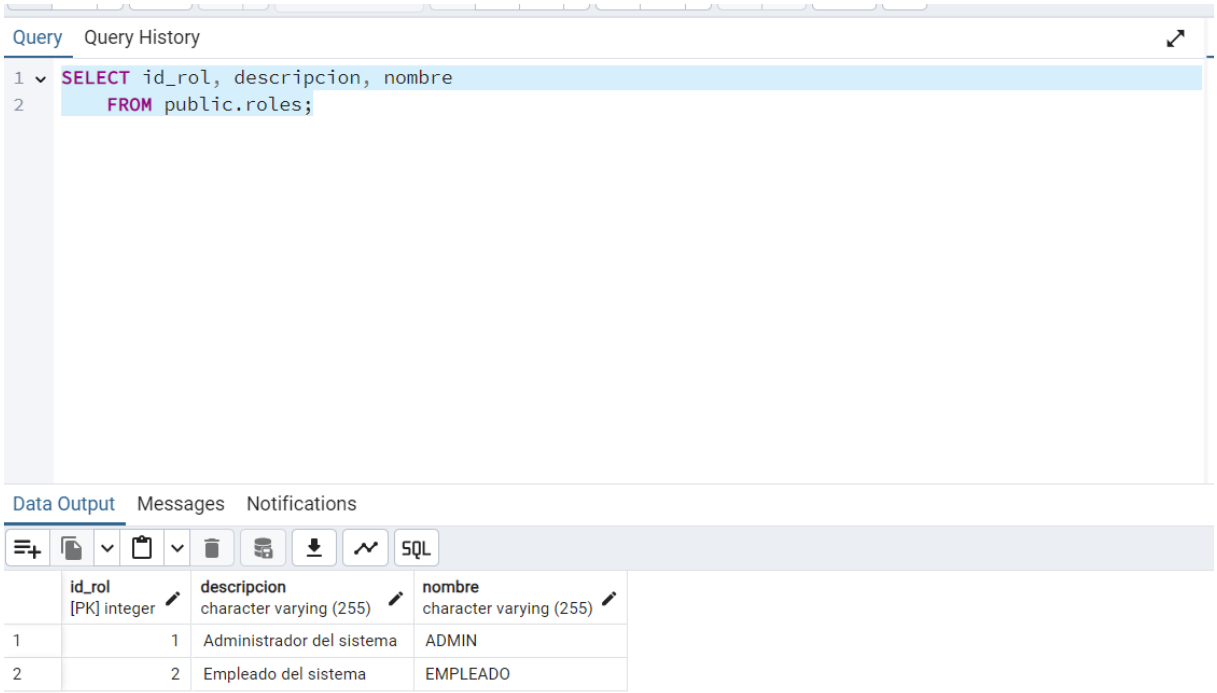

Figura 2. Consulta de verificación de roles (evidencia).

3.3 Crear o validar usuario administrador

Para ejecutar HU-RF-01 es necesario contar con un usuario Admin, ya que este rol es el único autorizado para crear usuarios. Si aún no existe, se registra en la base de datos.

Importante: la contraseña no debe almacenarse en texto plano. En las evidencias se observa un hash con prefijo "$2a$", formato típico de bcrypt. El valor original usado en el ejemplo fue "1524" (solo como dato de prueba).

Query Query History Scratch

```sql
INSERT INTO public.usuarios (email, estado, nombre, password, id_rol)
VALUES (
    'LeonardoJV@gmail.com',
    'ACTIVO',
    'Jose Leonardo Vargas',
    '$2a$10$mTohaQ4gHA9HioxLDgkGCe7huDU/QWddORtLDVJu82kzhR10qvWUW',
    1
);
```

Data Output Messages Notifications

```
INSERT 0 1

Query returned successfully in 114 msec.
```

Figura 3. Inserción/registro de usuario Admin en base de datos (evidencia).

3.4 Confirmar creación del Admin

Se consulta la tabla de usuarios para confirmar que el registro del Admin quedó creado y disponible para autenticación.

Query Query History Scratch Pad ×

```sql
SELECT id, email, estado, nombre, password, id_rol
    FROM public.usuarios;
```

Data Output Messages Notifications

	id [PK] bigint	email character varying (255)	estado character varying (255)	nombre character varying (255)	password character varying (255)	id_rol integer
1	1	LeonardoJV@gmail.com	ACTIVO	Jose Leonardo Vargas	$2a$10$mTohaQ4gHA9HioxLDgkGCe7huDU/QWddORtLDVJu82kzhR10qvWU...	1

Figura 4. Verificación del usuario Admin creado (evidencia).

4. Ejecución de la historia de usuario (flujo y criterios)

A continuación se documenta el flujo principal de HU-RF-01, organizado por criterios de aceptación. Cada criterio incluye el objetivo, la acción a realizar y la evidencia obtenida.

4.1 Crear usuario con datos obligatorios

Objetivo: registrar un nuevo usuario con los campos mínimos requeridos por el sistema.

Pasos:

1. Obtener un token válido del usuario Admin.
2. En Postman, ir a la pestaña Authorization y seleccionar Bearer Token.
3. Pegar el token del Admin en el campo correspondiente.
4. Consumir el endpoint de creación (ej. POST /usuarios) enviando un JSON con los campos obligatorios (nombre, email, contraseña, rol, etc.).

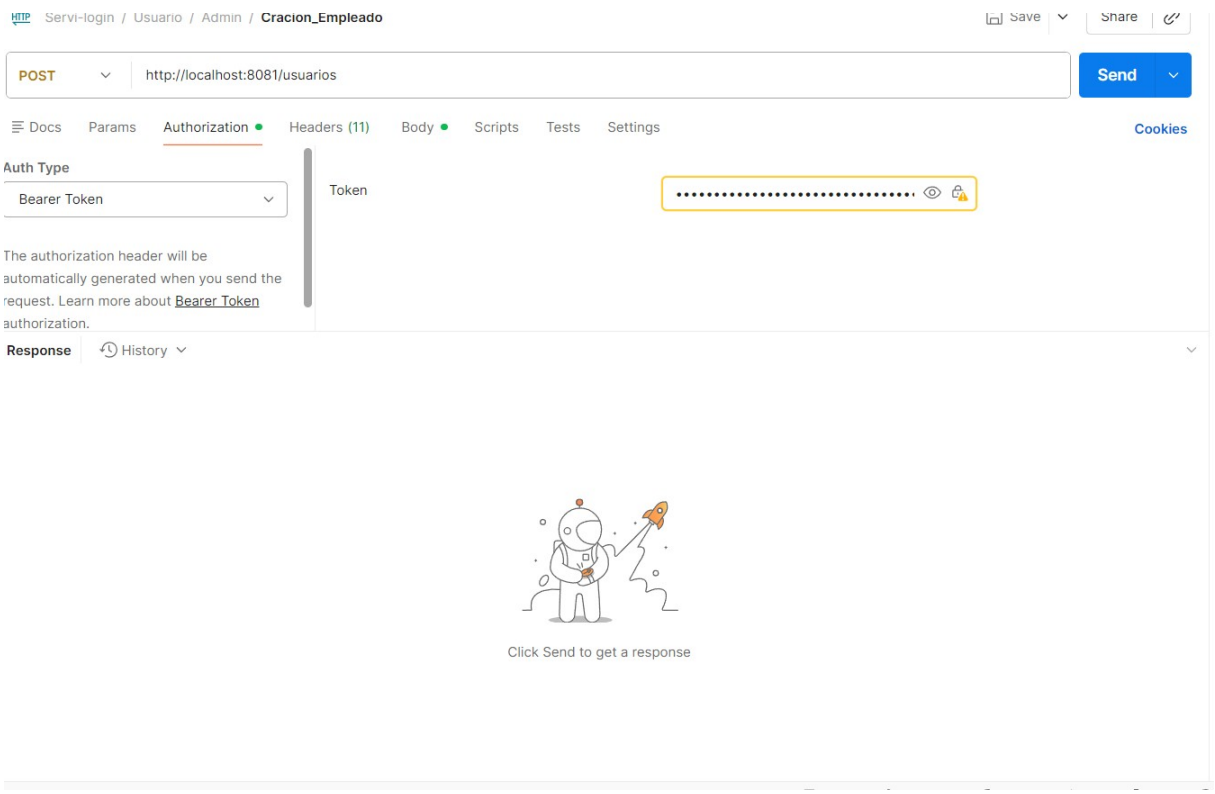

Figura 5. Petición de creación de usuario con datos obligatorios (evidencia).

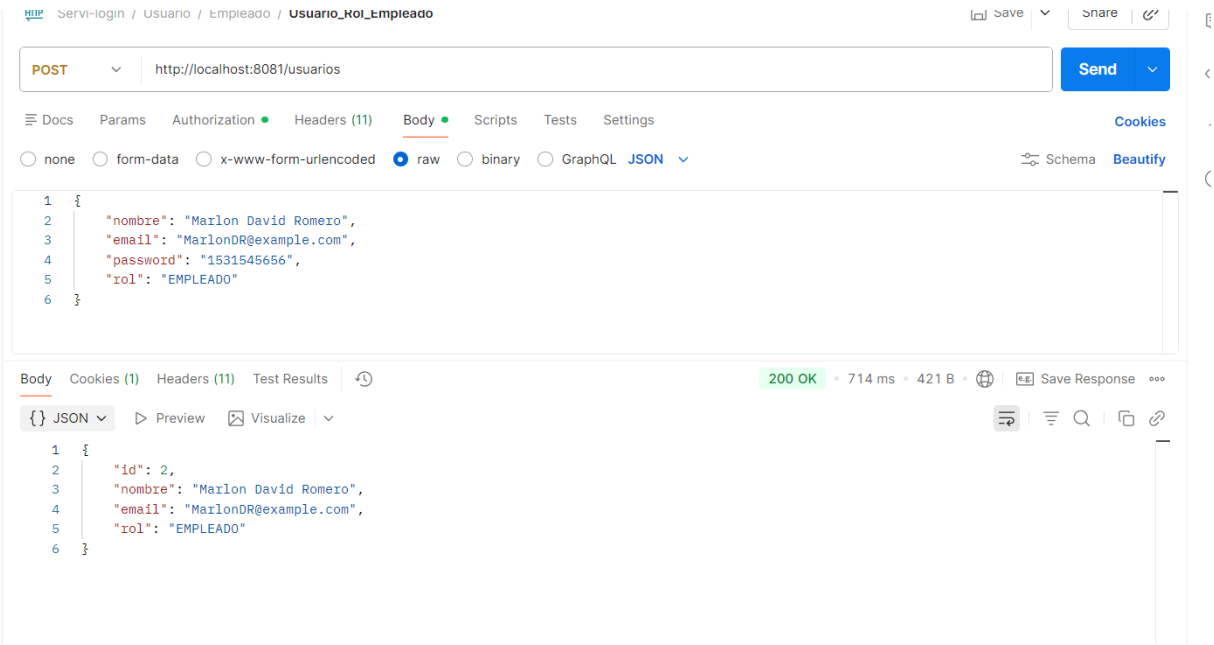

Figura 6. Configuración de Authorization con Bearer Token (evidencia).

4.2 Validar que no existan duplicados

Objetivo: comprobar que el sistema no permite crear el mismo usuario dos veces, ni registrar correos repetidos.

- Caso A - Usuario duplicado (mismo registro):
  - Se intenta enviar nuevamente la misma solicitud de creación. El sistema responde con error (403) indicando que el usuario ya existe.

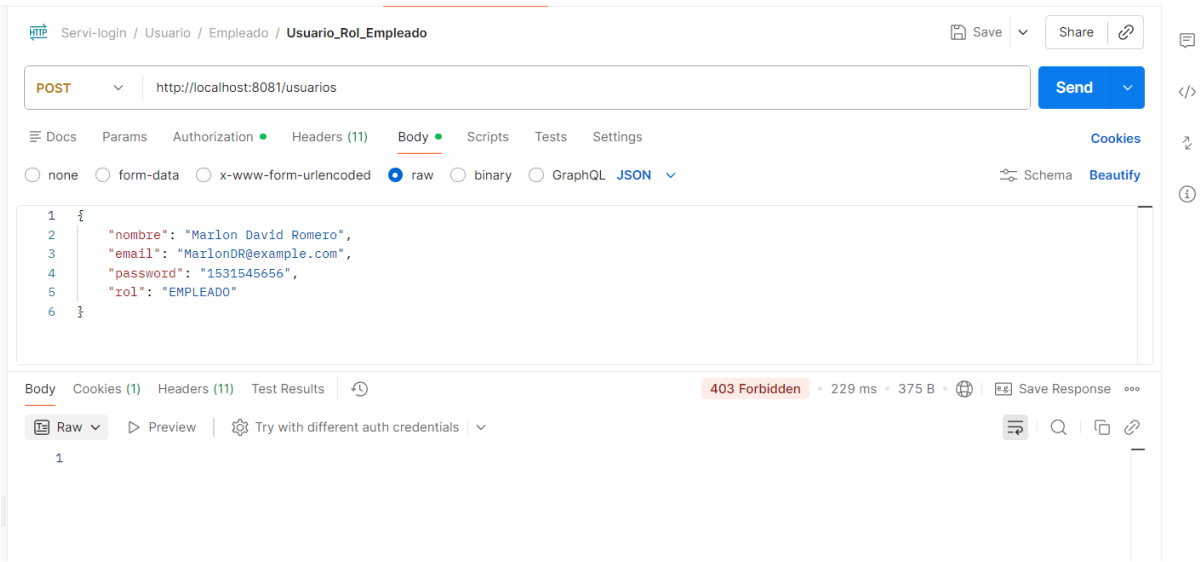

Figura 7. Error al intentar crear un usuario ya existente (evidencia).

- Caso B - Email duplicado (mismo correo, diferente usuario):
  - Se intenta crear un usuario con nombre y contraseña diferentes, pero usando el mismo email. El sistema rechaza la solicitud porque el correo ya está registrado.

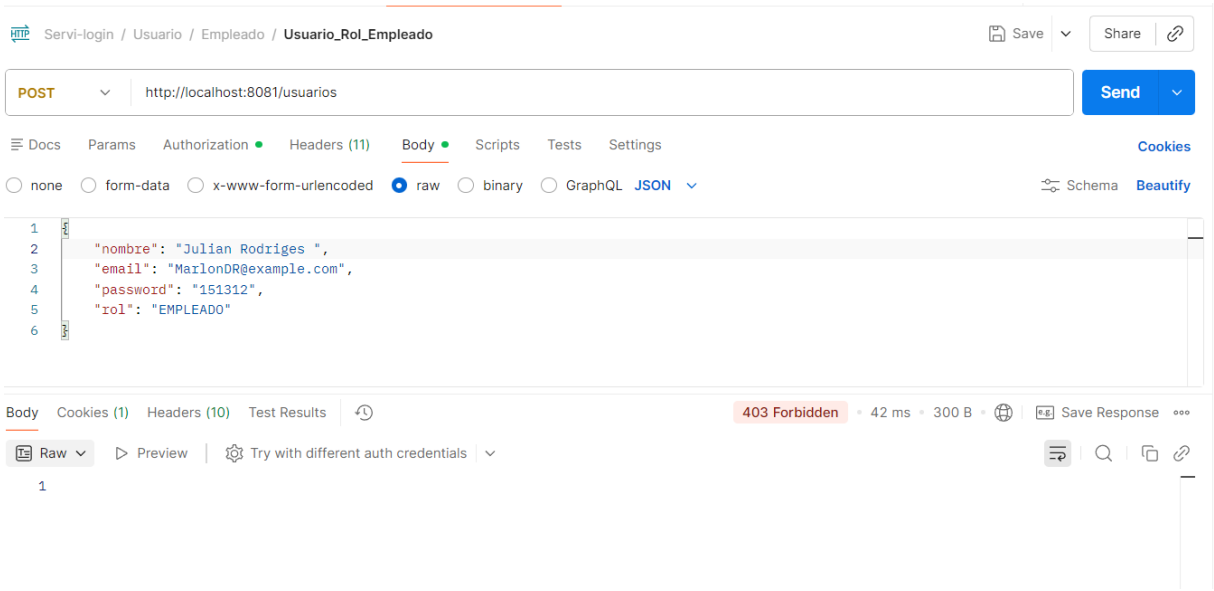

Figura 8. Error por email duplicado (evidencia).

4.3 Asignar rol (Administrador / Empleado)

Objetivo: verificar que, al crear un usuario, el sistema permite asignar un rol válido (por ejemplo: EMPLEADO o ADMIN) y que la asignación queda persistida.

- En las pruebas se evidencia la creación de un usuario con rol EMPLEADO y, adicionalmente, la creación de un usuario con rol ADMIN.

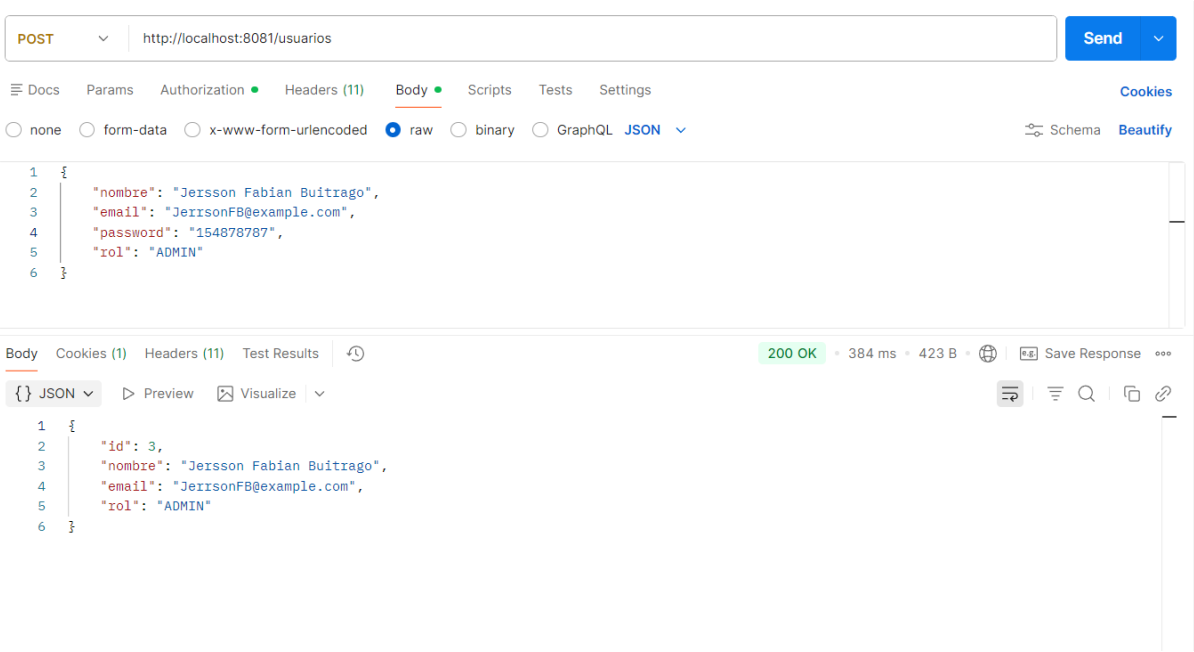

Figura 9. Creación de usuario con rol definido (evidencia).

4.4 Cifrado/Hash de contraseña

Objetivo: confirmar que las contraseñas no se almacenan en texto plano, sino en formato seguro (hash). Esto reduce el riesgo de exposición de credenciales ante fugas de datos.

- Verificación: se consulta la tabla de usuarios y se observa que el campo de contraseña contiene valores cifrados/hasheados.

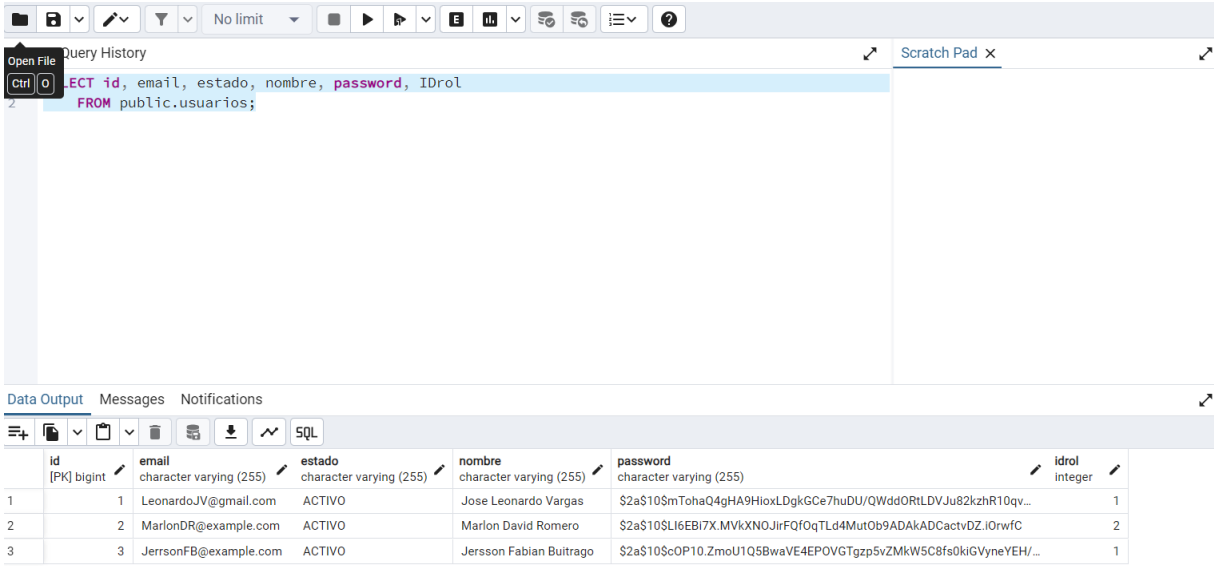

Figura 10. Contraseñas almacenadas como hash en base de datos (evidencia).

4.5 Registro de acción en bitácora

Objetivo: validar que el sistema registra en la bitácora las acciones críticas (por ejemplo, creación de usuario), incluyendo información relevante como: usuario que ejecuta la acción, fecha/hora y tipo de operación.

- Para consultar la bitácora se requiere un token de Admin, ya que este rol es el único autorizado para verla.

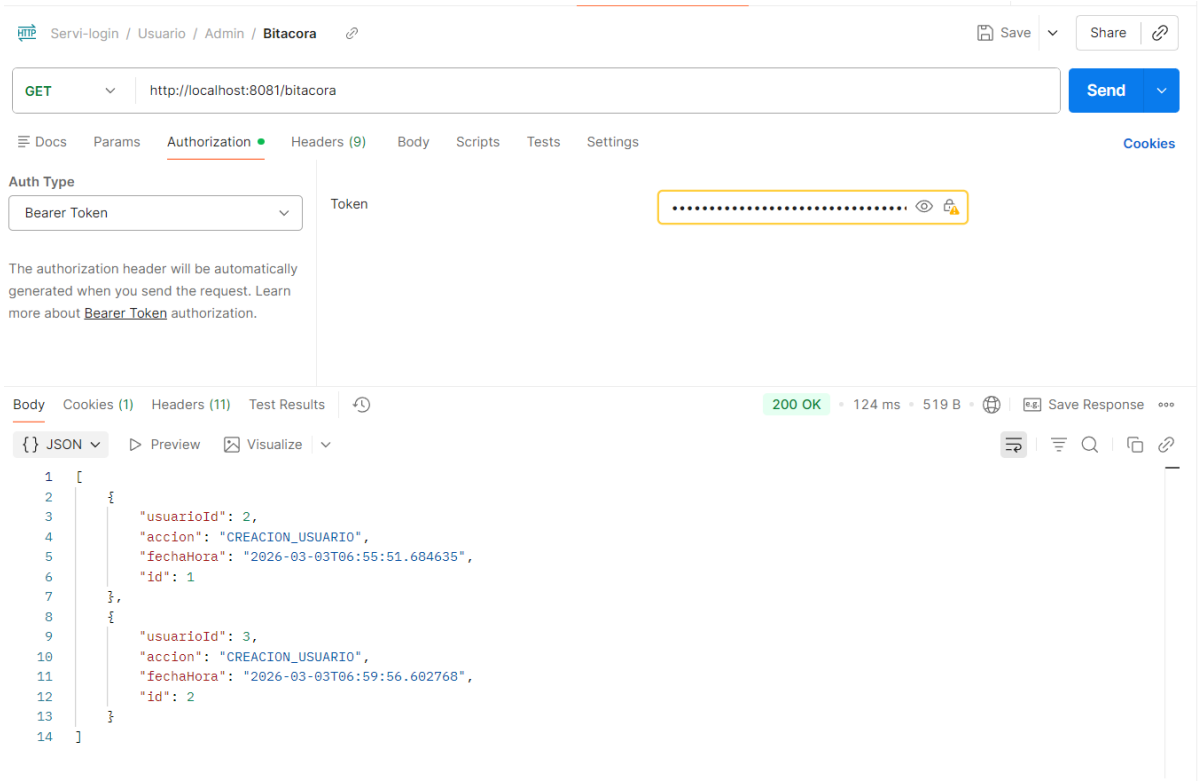

Figura 11. Consulta de bitácora con token Admin (evidencia).

5. Checklist de criterios de aceptación

Criterio	Resultado esperado	Evidencia
Crear usuario con datos obligatorios	Se crea el usuario y el sistema responde OK.	Figuras 5-6
Validar no duplicados	Rechaza usuario repetido y rechaza email repetido (403 o equivalente).	Figuras 7-8
Asignar rol	Permite rol ADMIN/EMPLEADO y lo guarda.	Figura 9
Contraseña segura	Contraseña almacenada como hash, no texto plano.	Figura 10
Registro en bitácora	Acción crítica registrada y consultable por Admin.	Figura 11

6. Observaciones

1) Los códigos de error pueden variar según la implementación (403, 409, etc.). Lo importante es que el sistema bloquee la duplicidad.
2) Si se cambia el mecanismo de hash (bcrypt, HMAC SHA-256 u otro), se debe mantener el mismo criterio: no almacenar contraseñas en texto plano y validar credenciales comparando hashes.
3) Mantener la bitácora como un registro inmutable para auditoría.